PLAYBOOK NO. 11 · AI SECURITY

Securing AI. The new attack surface.

What changes when your people, systems and attackers all start using AI, and the practical controls that keep you in charge.

INSIDE

Contents

The new risks that arrive with AI assistants and agents, the controls that genuinely reduce them, and how to test, monitor and respond when something goes wrong.

Foreword 03

Introduction 04

01 What changes with AI 06

02 Controls that work 11

03 Test, watch and respond 17

FOREWORD

AI is a new way in. Treat it like one.

Every time a new technology joins the business, it brings new doors with it. Email brought phishing. The cloud brought misconfigured storage. AI assistants and agents bring something different again: software that reads untrusted text, makes decisions about it and, increasingly, takes action on your behalf.

Most of the security basics still apply. Identity, least privilege, logging, patching and training matter as much as ever. But some risks are genuinely new, such as prompt injection, and some familiar ones move faster, such as convincing phishing and fraudulent calls that sound exactly like your finance director.

This playbook is written for leaders who want to adopt AI with their eyes open. It explains the risks in plain English, sets out the controls that make the biggest difference, and gives you the questions to ask your security team and your suppliers.



The Transputec team
Transputec

INTRODUCTION

Secure AI is mostly good security, applied early.

You do not need a separate security programme for AI. You need your existing one to understand where AI changes the picture, and to be involved before tools are switched on rather than after.

Know what is in use

You cannot protect AI tools you do not know about. Start with an honest inventory of approved and unapproved use.

Limit what AI can reach and do

Most serious incidents come from assistants with too much access. Give them the least they need, and nothing more.

Watch, test and rehearse

Log AI activity, test it the way an attacker would, and know who does what when something goes wrong.

An AI assistant is only as trustworthy as the least trusted thing it reads.

Once AI can read emails, web pages and documents from outside your organisation, anyone who can write to those places can try to give it instructions.

01

PART 01

What changes.

The risks that are new, the risks that are faster, and the ones that were always there.

01 The new attack surface

02 Five risks to understand

03 Prompt injection up close

THE NEW ATTACK SURFACE

Why AI changes the security conversation

> **Most AI risk is ordinary security risk with a new front door. Close the door before you furnish the room.**

Traditional software does what its code says. An AI assistant does what its instructions say, and its instructions are written in ordinary language that can arrive from almost anywhere: the user, a document, a web page, an email or a tool it has been connected to. That is what makes assistants so useful, and it is also what makes them a new kind of target.

The first and most common risk is not exotic at all. It is people pasting customer lists, contracts, source code or board papers into whichever AI tool is nearest to hand, often a personal account with consumer terms. Data leakage through unapproved tools is the everyday AI risk, and it is driven by good intentions rather than malice.

The second shift is that AI now acts. Assistants connected to email, files, calendars, ticketing systems and code repositories can read and change things. Agents can take a series of steps on their own. Each connection extends the reach of anyone who can influence what the assistant does, which is why access and permissions matter more than ever.

The third shift is on the other side. Attackers use AI too. Phishing emails arrive in flawless English and reference real projects. Cloned voices and video can impersonate senior people convincingly. Vulnerabilities can be found and exploited more quickly. Defences built on spotting bad grammar or a slightly wrong voice are no longer enough.

None of this means AI is too risky to use. It means AI needs to be brought inside your security programme: inventoried, governed, permissioned, logged and tested, just like any other system that handles sensitive data and can take action.

The good news is that the controls that work are mostly familiar. Approved tools, strong identity, least privilege, human approval for consequential actions, good logging and regular testing will deal with the majority of the risk. The rest of this playbook shows how to apply them.

FIVE RISKS

The risks that matter most

Four you can control directly, plus a fifth that comes from outside.

Data leakage

Sensitive information pasted into unapproved tools, or surfaced by an assistant to someone who should not see it.

Prompt injection

Hidden or crafted instructions, in a message or a document, that steer the assistant away from what the user intended.

Insecure output handling

AI output passed straight into code, emails, databases or web pages without checks, so a bad answer becomes a bad action.

Excessive agency

Assistants and agents with broader access or autonomy than their job needs, which turns a small mistake into a large one.

> **The fifth risk is the supply chain: models, data, plugins and connectors from third parties that you are trusting without checking.**

01

Prompt injection, up close

The risk most specific to AI, and one that no supplier has fully solved. Plan on the assumption that it will sometimes succeed.

DIRECT INJECTION

A user types instructions designed to override the assistant's rules, for example to reveal its configuration or ignore its guardrails.

INDIRECT INJECTION

Instructions hidden in content the assistant reads, such as an email, web page or shared file, written by someone outside your organisation.

WHY IT MATTERS

If the assistant can send email, move files or call systems, a successful injection can leak data or take actions in the user's name.

WHAT REDUCES IT

Limit permissions, require human approval for sensitive actions, separate trusted and untrusted content, and log what the assistant does.

OWNER

Security lead, with each AI product owner

Bring this to the monthly review, with a date for each action.

RISK REGISTER

From risk to control

A starting register to adapt for your own tools and data.

RISK	WHAT IT LOOKS LIKE	FIRST CONTROLS
Data leakage	Staff paste client data into a personal AI account.	Approved tools, a clear policy, and blocking of unapproved services where practical.
Oversharing	An assistant surfaces salary files to anyone who asks.	Fix permissions and sensitivity labels before connecting AI to your files.
Prompt injection	A web page tells an agent to email out a document.	Least privilege, approval steps for actions, and monitoring of agent activity.
Unsafe output	Generated code or scripts run without review.	Human review, testing and the same controls as any other code change.
Supply chain	An unvetted plugin or model file is installed.	Approved sources only, supplier due diligence and an inventory of AI components.
AI-enabled fraud	A cloned voice asks finance to pay a new supplier.	Call-back verification and dual approval for payments and bank detail changes.

02

PART 02

Controls that work.

Practical measures that reduce most of the risk without stopping people using AI well.

01 Five security principles

02 Permissions and agents

03 When attackers use AI

PRINCIPLES

Five principles for securing AI

Simple rules your security team, suppliers and AI product owners can all work to.

01 Approve the tools, and make them easy to reach

If the approved route is slower than a personal account, people will use the personal account. Remove the friction.

02 Grant the least access that does the job

Assistants inherit permissions. Scope connectors, service accounts and agent tools to the task, and review them regularly.

03 Treat everything AI reads as untrusted

Emails, web pages and shared files may carry instructions. Design as if some of them are hostile.

04 Keep a person on consequential actions

Payments, deletions, external emails and changes to systems should need a human click, not just a model's decision.

05 Log it, test it and own it

Every AI system has a named owner, activity that can be reviewed, and a test before and after go-live.

BEFORE AND AFTER

Unmanaged AI versus secured AI

The difference is rarely one product. It is a set of decisions made on purpose.

AREA	UNMANAGED	SECURED
Tools	Whatever staff find, often on personal accounts.	Approved, business-grade tools with suitable data terms.
Identity	Shared logins and personal sign-ups.	Single sign-on, multi-factor authentication and leaver processes that include AI.
Access	Connectors switched on with broad permissions.	Scoped access, cleaned-up file permissions and regular reviews.
Actions	Agents act freely across systems.	Approval steps for anything sensitive or hard to reverse.
Visibility	No record of prompts, outputs or actions.	Logs retained and fed into security monitoring.
Assurance	Trust the supplier's marketing.	Due diligence, testing and contract terms you have read.

AGENTS AND PERMISSIONS

How much freedom should an agent have?

Plot each assistant or agent by the sensitivity of what it can reach and how independently it can act.

↑ DATA SENSITIVITY

TIGHT GUARDRAILS

Sensitive data, low autonomy

Reads sensitive material but only suggests. Focus on access control and logging.

HIGHEST RISK

Sensitive data, high autonomy

Acts on its own with sensitive data. Needs approvals, strict scoping, monitoring and testing.

LOW RISK

General data, low autonomy

Drafting and summarising public or internal content. Standard policy is enough.

WATCH CLOSELY

General data, high autonomy

Acts independently on low-risk data. Limit what it can change and keep an audit trail.

AUTONOMY →

WHEN ATTACKERS USE AI

Three attacks to prepare for

FINANCE

The cloned voice of a director

THE ATTACK

A call or video message, apparently from a senior leader, urges an urgent payment.

THE CONTROL

Call back on a known number, and dual approval for payments and bank changes.

WHY IT WORKS

Voice and video cloning can be convincing, and urgency discourages checks.

WHAT GOOD LOOKS LIKE

Staff are thanked, not criticised, for pausing to verify a senior request.

EVERYONE

Phishing that reads perfectly

THE ATTACK

Well-written emails that reference real suppliers, projects or colleagues.

THE CONTROL

Phishing-resistant multi-factor authentication, email filtering and easy reporting.

WHY IT WORKS

Spelling mistakes and awkward phrasing are no longer reliable warning signs.

WHAT GOOD LOOKS LIKE

Training focuses on unusual requests and process, not on spotting typos.

IT

Faster discovery of weak spots

THE ATTACK

Attackers use AI to scan for and exploit known vulnerabilities more quickly.

THE CONTROL

Prompt patching, an accurate asset inventory and continuous vulnerability scanning.

WHY IT WORKS

The gap between a flaw being published and being exploited keeps shrinking.

WHAT GOOD LOOKS LIKE

Critical patches applied quickly, with internet-facing systems prioritised.

IDENTITY AND SUPPLY CHAIN

Trust nothing you have not checked

> **Every agent, plugin and API key is an identity. If nobody owns it, nobody is watching it.**

AI tools are only as secure as the identities that use them. Put every approved AI service behind single sign-on with multi-factor authentication, so access follows your joiners, movers and leavers process. When someone leaves, their access to the assistant, its history and any agents they built should end on the same day as everything else.

Agents and integrations often run under service accounts or API keys rather than a person. These deserve particular care. Give each one its own identity, scope it tightly, store its secrets in a proper vault, rotate them, and make sure someone owns it. An unowned service account with broad access is an incident waiting to happen.

The AI supply chain is wider than it looks. It includes the model provider, any open models your teams download, the data used to tune or ground them, plugins, connectors, browser extensions and the libraries developers pull in. Each is a dependency you are trusting with data or behaviour.

Some model files can contain code that runs when the file is loaded, so models should come from reputable sources, be scanned, and use safer formats where they are available. Training and reference data can be deliberately poisoned to change how a model behaves. Plugins and extensions can request far more access than they need.

Treat AI components like any other third-party software. Keep an inventory, approve sources, review permissions before installation, and run supplier due diligence on data handling, retention, sub-processors and where data is stored. Read the contract terms on whether your data is used for training.

Finally, make sure AI activity is visible. Prompts, outputs, connector access and agent actions should be logged in a way your security team can search and alert on, with retention that balances investigation needs against privacy.

03

PART 03

Test, watch, respond.

Assume something will eventually get through, and be ready when it does.

01 Red teaming AI

02 Frameworks worth knowing

03 Incident response

RED TEAMING

Test it the way an attacker would

Before go-live and after every significant change, try to make your AI misbehave on purpose.

01 **Map what it can reach and do**

List the data, connectors and actions each assistant or agent can use. That is your scope.

02 **Try to override its instructions**

Ask it to ignore its rules, reveal its configuration or act outside its role.

03 **Plant hostile content**

Hide instructions in documents, emails or pages it reads, and see whether it obeys.

04 **Test the output path**

Check what happens when output flows into code, email, databases or web pages.

05 **Check for oversharing**

Sign in as ordinary users in different roles and ask for things they should not see.

06 **Fix, retest and record**

Close the gaps, repeat the tests and keep the results as evidence for your risk register.

REMEMBER

Models, prompts, connectors and permissions all change. Each change can reopen a door.

FRAMEWORKS

Reference points worth knowing

Useful, freely available guidance. These are updated over time, so always check the current version.

REFERENCE	WHAT IT IS	USE IT FOR
OWASP Top 10 for LLM Applications	A community list of the most important security risks in applications built on large language models.	A shared vocabulary for developers, testers and suppliers.
MITRE ATLAS	A knowledge base of adversary tactics and techniques against AI systems, in the style of MITRE ATT&CK.	Threat modelling and planning red team exercises.
NCSC secure AI guidelines	UK-led guidelines for secure AI system development, covering design, development, deployment, operation and maintenance.	Questions for suppliers and internal build teams.
NIST AI Risk Management Framework	A voluntary framework from the US standards body for managing AI risk.	Structuring wider AI risk governance.
ISO/IEC 42001	An international standard for AI management systems.	Organisations that want a certifiable AI management approach.

INCIDENT RESPONSE

When an AI incident happens

Extend your existing incident plan rather than writing a new one. These are the AI-specific steps to add.

Detect

Recognise AI incidents: leaked data, unexpected agent actions, injected content or fraud using cloned voices.

Contain

Disable the affected connector, agent or API key, and revoke tokens. Know who has authority to switch AI off.

Investigate

Use prompt, output and action logs to establish what the AI saw, said and did, and what data was involved.

Recover

Reverse unwanted actions, correct permissions and notify affected people or regulators where required.

Learn

Update tests, guardrails and training, and add the scenario to your next red team exercise.

> **If personal data is involved, your UK GDPR breach assessment and reporting duties apply as they would for any other incident.**

ASK YOUR TEAM

Questions for security and suppliers

Use these in leadership reviews, supplier meetings and before any AI tool goes live.

FOR YOUR SECURITY TEAM

- ? Do we know which AI tools are in use, including ones we have not approved?
- ? Which assistants or agents can take actions, and what are they allowed to do?
- ? Are AI prompts, outputs and actions logged where we can investigate them?
- ? When did we last test an AI system for prompt injection or oversharing?

FOR YOUR AI SUPPLIERS

- ? Is our data used to train models, and where is it stored and processed?
- ? How do you defend against prompt injection, and what is left to us?
- ? What logs and admin controls do we get, and how long are they kept?

CHECKLIST

Is your AI secure enough?

Tick what is in place today. Anything left blank is your next step.

- [ ] **An inventory of AI tools, agents and integrations**
  Including unapproved use you have discovered.

- [ ] **Approved tools behind single sign-on and MFA**
  With leavers removed on the same day.

- [ ] **File permissions cleaned up before AI is connected**
  So assistants cannot surface what users should not see.

- [ ] **Least privilege for agents, plugins and API keys**
  Each with a named owner and a review date.

- [ ] **Human approval for consequential actions**
  Payments, deletions, external messages and system changes.

- [ ] **AI activity logged and monitored**
  Prompts, outputs, connector access and agent actions.

- [ ] **AI scenarios in testing and incident response**
  Prompt injection, oversharing, deepfake fraud and leaked data.

GLOSSARY

Words worth knowing

Prompt injection

Crafted instructions that try to make an AI system ignore its rules or act against the user's intent.

Indirect prompt injection

Injection hidden in content the AI reads, such as an email, web page or file.

Excessive agency

An AI system with more access, permissions or autonomy than its task needs.

Insecure output handling

Using AI output in code, systems or web pages without validation.

Data poisoning

Deliberately corrupting training or reference data to change how a model behaves.

Shadow AI

AI tools used without the organisation's knowledge or approval.

Red teaming

Testing a system by deliberately trying to make it fail or misbehave, as an attacker would.

Deepfake

AI-generated audio, image or video that imitates a real person.

Least privilege

Giving a person or system only the access it needs to do its job.

Service account

A non-human identity used by an application, integration or agent.

Guardrails

Controls that limit what an AI system will accept, say or do.

Single sign-on

One managed login for many services, so access can be granted and removed centrally.

TRANSPUTEC

Adopt AI without opening new doors.

We help organisations secure the AI tools they use, from permissions and identity to monitoring, testing and incident response, so teams can move quickly and safely.

Book an AI security review

transputec.com

ALSO IN THE SERIES

No. 12 · Your data, AI-ready